07-4-external-secrets-iam-policy

accounts-api security assessment · generated from the repository, not hand-edited


```
{
  "_comment": [
    "IRSA policy for the External Secrets Operator / Secrets Store CSI driver service account.",
    "Threat T2. Deliberately a SEPARATE role from the pod's (iam/pod-identity-policy.json):",
    "the operator can read the secrets it is asked to sync, the pod can read exactly one.",
    "Collapsing the two — which is the common shortcut — means every workload's identity",
    "inherits the operator's breadth, and the least-privilege work in the pod policy is undone."
  ],
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ReadOnlyTheSecretsThisOperatorSyncs",
      "Effect": "Allow",
      "Action": [
        "secretsmanager:GetSecretValue",
        "secretsmanager:DescribeSecret"
      ],
      "Resource": [
        "arn:aws:secretsmanager:ap-south-1:123456789012:secret:prod/accounts-api/*"
      ],
      "Condition": {
        "ForAnyValue:StringEquals": {
          "secretsmanager:VersionStage": "AWSCURRENT"
        }
      }
    },
    {
      "Sid": "ListIsScopedByTheResourceTagOnEachSecret",
      "Effect": "Allow",
      "Action": "secretsmanager:ListSecrets",
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:ResourceTag/ManagedBy": "external-secrets"
        }
      }
    },
    {
      "Sid": "DecryptViaSecretsManagerOnly",
      "Effect": "Allow",
      "Action": "kms:Decrypt",
      "Resource": "arn:aws:kms:ap-south-1:123456789012:key/8f1c2b4e-2a77-4d31-9f0e-6d1a5c3b7e42",
      "Condition": {
        "StringEquals": {
          "kms:ViaService": "secretsmanager.ap-south-1.amazonaws.com"
        }
      }
    },
    {
      "Sid": "NeverWriteASecret",
      "Effect": "Deny",
      "Action": [
        "secretsmanager:PutSecretValue",
        "secretsmanager:UpdateSecret",
        "secretsmanager:CreateSecret",
        "secretsmanager:DeleteSecret",
        "secretsmanager:RestoreSecret",
```

```
        "secretsmanager:RotateSecret",
        "secretsmanager:UpdateSecretVersionStage",
        "secretsmanager:PutResourcePolicy"
      ],
      "Resource": "*"
    },
    {
      "Sid": "DenyIdentityMutationAndRoleChaining",
      "Effect": "Deny",
      "Action": ["iam:*", "sts:AssumeRole", "organizations:*"],
      "Resource": "*"
    },
    {
      "Sid": "DenyEverythingOutsideApSouth1",
      "Effect": "Deny",
      "NotAction": ["iam:*", "sts:*"],
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": "ap-south-1"
        }
      }
    }
  ]
}
```